

Red Team Recon

Informe Técnico – luminor.lv

Reconocimiento Externo, Validación Técnica y Análisis OSINT



Proyecto: Bootcamp KeepCoding 2026

Módulo: Red Team / Reco

Ref: KC-2026-RT-002

Analista: Dani García (geoSp)

Fecha: Abril 2026

INFORME DE RECONOCIMIENTO

USO ACADÉMICO / ENTORNO FORMATIVO

Proyecto realizado en el marco del Bootcamp KeepCoding 2026

Objetivo evaluado: *.luminor.lv

Periodo de análisis: abril 2026

Analista: Dani García (geoSp)

luminor.lv – Reconocimiento Externo, Validación Técnica y Análisis OSINT

Anexo Reconocimiento Externo de Superficie Web

1. Contexto del análisis

Como parte del ejercicio práctico de Red Team del bootcamp, se realizó una fase complementaria de reconocimiento externo sobre una organización real, he aprovechado para testear una herramienta propia de automatización de reconocimiento denominada **Cerberus Search**.

El objetivo principal de este anexo no es demostrar explotación ni compromiso de sistemas, sino documentar una fase inicial de reconocimiento externo orientada a:

- Enumerar activos públicos.
- Identificar subdominios vivos.
- Detectar infraestructura CDN/WAF.
- Analizar exposición preliminar de servicios.
- Priorizar activos interesantes para una posible fase posterior de análisis manual.
- Evaluar la utilidad de una herramienta propia dentro de una metodología Red Team / Bug Bounty.

2. Datos generales del análisis

Campo	Valor
Target	luminor.lv
Tipo de análisis	Reconocimiento externo
Modo	Bug Bounty
Scope utilizado	Vertical
Fecha	26/04/2026
Herramienta	Cerberus Search

Campo	Valor
Informe generado	<code>report_luminor.lv_20260426_184022.md</code>
Ruta local	<code>results/luminor.lv/bugbounty_vertical_20260426_182144/</code>

3. Objetivo del reconocimiento

El objetivo de esta fase fue construir una visión inicial de la superficie pública de una organización real desde una perspectiva ofensiva controlada.

En concreto, se buscó identificar:

- Subdominios asociados al dominio principal.
- Subdominios resolubles por DNS.
- Hosts vivos vía HTTP/HTTPS.
- URLs y ficheros JavaScript expuestos.
- Presencia de WAF/CDN.
- Posibles problemas TLS.
- Puertos detectados en una fase preliminar de escaneo.
- Activos que pudieran requerir revisión manual posterior.

Este reconocimiento se realizó como apoyo académico al ejercicio de Red Team, con finalidad documental y metodológica.

4. Alcance y limitaciones

4.1 Alcance

El dominio analizado fue:

```
*.luminor.lv
```

A partir de este dominio se realizó una enumeración vertical de activos asociados, incluyendo subdominios, servicios web vivos y recursos relacionados.

4.2 Limitaciones

Este análisis debe entenderse como una fase inicial de reconocimiento. No se realizaron acciones de explotación, intrusión, fuerza bruta, bypass de autenticación, fuzzing agresivo ni pruebas destructivas.

El informe generado por la herramienta debe interpretarse con criterio técnico, ya que algunos resultados pueden corresponder a infraestructura de terceros, como CDN, WAF o proveedores

cloud.

Especialmente, los puertos detectados en IPs asociadas a Cloudflare no deben interpretarse automáticamente como servicios internos expuestos por la organización objetivo.

4.3 Consideraciones éticas

El reconocimiento se limitó a la recopilación y análisis de información externa accesible públicamente, junto con comprobaciones técnicas iniciales no intrusivas.

No se accedió a información privada, no se intentó evadir controles de seguridad y no se ejecutaron pruebas de explotación contra sistemas de producción.

5. Resumen ejecutivo

El reconocimiento externo sobre `luminor.lv` permitió identificar una superficie pública amplia, formada por numerosos subdominios, servicios web activos, entornos aparentemente asociados a desarrollo, staging, testing y UAT, así como activos relacionados con banca, inversión, onboarding y servicios empresariales.

La herramienta identificó un volumen relevante de activos vivos:

Métrica	Valor
Subdominios encontrados mediante reconocimiento pasivo	78
Subdominios resueltos por DNS	51
Subdominios vivos vía HTTP/HTTPS	41
URLs encontradas	79
Ficheros JavaScript detectados	15
IPs únicas	11
Puertos detectados en escaneo preliminar	318

La herramienta marcó inicialmente el resultado como **Risk Level: HIGH**. Sin embargo, tras revisar manualmente la evidencia disponible, la clasificación más prudente sería:

Categoría	Evaluación
Riesgo confirmado	Bajo/Medio
Riesgo potencial de superficie	Medio/Alto
Valor de reconocimiento	Alto
Vulnerabilidades confirmadas	Ninguna

Categoría	Evaluación
Explotabilidad demostrada	No confirmada

El resultado más importante del análisis no es la confirmación de una vulnerabilidad crítica, sino la identificación de una superficie de ataque relevante que podría servir como punto de partida para una fase posterior de revisión manual, siempre bajo autorización y respetando el alcance permitido.

6. Superficie de ataque identificada

Durante la fase de reconocimiento se identificaron 78 subdominios, de los cuales 51 resolvían por DNS y 41 respondían vía HTTP/HTTPS.

6.1 Subdominios vivos HTTP/HTTPS

La herramienta identificó los siguientes subdominios vivos:

```
alb.new.luminor.lv
api.manapensija.luminor.lv
api.stg.manapensija.luminor.lv
autodiscover.luminor.lv
bloom.luminor.lv
business-join.luminor.lv
business-onboarding.luminor.lv
business-remote.luminor.lv
business-videocall.luminor.lv
cdnpb.ib.luminor.lv
enterpriseenrollment.luminor.lv
enterpriseregistration.luminor.lv
ib.luminor.lv
investments.luminor.lv
join.luminor.lv
kredits.luminor.lv
kredits.stg.luminor.lv
kredits.tst.luminor.lv
luminor.lv
manapensija-new.luminor.lv
manapensija.dev.luminor.lv
manapensija.luminor.lv
manapensija.stg.luminor.lv
manapensija.tst.luminor.lv
msoid.luminor.lv
nakotneses.luminor.lv
old.luminor.lv
onboarding.luminor.lv
photo-onboarding.luminor.lv
pp-investments.luminor.lv
remote.luminor.lv
```

```
sllv-secure.luminor.lv  
stage-aws.luminor.lv  
stage.luminor.lv  
stg.manapensija.luminor.lv  
test.luminor.lv  
tracking.mail.luminor.lv  
trade.luminor.lv  
uat-investments.luminor.lv  
videocall.luminor.lv  
www.luminor.lv
```

7. Clasificación funcional de activos

Para interpretar mejor la superficie encontrada, los activos se agruparon según su función aparente.

Esta clasificación no debe entenderse como una afirmación definitiva sobre la función interna de cada sistema, sino como una inferencia basada en el naming de los subdominios.

7.1 Activos corporativos y web pública

```
luminor.lv  
www.luminor.lv  
old.luminor.lv  
bloom.luminor.lv  
nakotneses.luminor.lv
```

Estos activos parecen corresponder a presencia web pública, portales corporativos, servicios informativos o versiones anteriores de la web.

Interés desde Red Team

Este grupo suele ser útil para:

- Identificación de tecnologías.
- Revisión de cabeceras HTTP.
- Enumeración de rutas públicas.
- Análisis de formularios.
- Detección de versiones antiguas.
- Identificación de contenido histórico o legacy.

El subdominio `old.luminor.lv` resulta especialmente interesante por su nomenclatura, ya que podría apuntar a una versión antigua o heredada de algún servicio. No obstante, la existencia de este nombre no implica por sí misma una vulnerabilidad.

7.2 Banca, inversión y servicios financieros

```
ib.luminor.lv  
cdnpb.ib.luminor.lv  
investments.luminor.lv  
trade.luminor.lv  
pp-investments.luminor.lv  
uat-investments.luminor.lv
```

Este grupo es uno de los más sensibles por su aparente relación con banca online, inversión o trading.

Interés desde Red Team

Desde una perspectiva ofensiva controlada, estos activos tendrían una prioridad elevada debido al posible impacto de cualquier fallo de seguridad en flujos financieros.

Áreas que podrían requerir revisión manual:

- Autenticación.
- Autorización.
- Gestión de sesiones.
- Flujos de inversión o trading.
- APIs financieras.
- Tokens temporales.
- CORS.
- Redirecciones.
- Exposición de datos sensibles.
- Separación entre producción, preproducción y UAT.

Nota de cautela

Los activos financieros suelen estar sujetos a controles estrictos y a reglas de scope muy concretas en programas de Bug Bounty. Cualquier validación adicional debería realizarse únicamente si el alcance autorizado lo permite.

7.3 Onboarding, acceso remoto y videollamada

```
onboarding.luminor.lv  
photo-onboarding.luminor.lv  
business-onboarding.luminor.lv  
business-join.luminor.lv  
business-remote.luminor.lv  
business-videocall.luminor.lv
```

```
remote.luminor.lv  
videocall.luminor.lv  
join.luminor.lv
```

Este bloque resulta especialmente relevante porque parece estar relacionado con procesos de alta, incorporación de usuarios o empresas, acceso remoto y videollamada.

Interés desde Red Team

Los flujos de onboarding suelen ser atractivos para un análisis de seguridad porque pueden incluir:

- Registro de usuarios.
- Verificación de identidad.
- Subida de documentos.
- Validación por videollamada.
- Tokens de invitación.
- Formularios multipaso.
- Acceso a estados intermedios.
- Integraciones con terceros.

Posibles líneas de revisión

En una fase posterior autorizada podrían revisarse:

- IDOR.
- Control de acceso horizontal.
- Control de acceso vertical.
- Manipulación de parámetros.
- Bypass de pasos del flujo.
- Exposición de documentos.
- Subida insegura de archivos.
- Reutilización de tokens.
- Tokens predecibles.
- Falta de expiración de enlaces.
- Open redirect.
- CORS mal configurado.
- Gestión incorrecta de sesiones.

Valor para el informe

Aunque no se haya probado ninguna vulnerabilidad, este bloque demuestra la capacidad del reconocimiento para identificar activos de mayor sensibilidad funcional.

7.4 APIs y servicios asociados a pensiones/crédito


```
api.manapensija.luminor.lv
api.stg.manapensija.luminor.lv
manapensija.luminor.lv
manapensija-new.luminor.lv
manapensija.dev.luminor.lv
manapensija.stg.luminor.lv
manapensija.tst.luminor.lv
stg.manapensija.luminor.lv
kredits.luminor.lv
kredits.stg.luminor.lv
kredits.tst.luminor.lv
```

Este grupo incluye activos asociados aparentemente a APIs, servicios financieros, crédito, pensiones o entornos auxiliares.

Interés desde Red Team

Los activos con nombres como `api`, `dev`, `stg`, `tst` o `new` son relevantes durante el reconocimiento porque pueden exponer:

- APIs públicas.
- Endpoints internos.
- Documentación técnica.
- Configuraciones de entorno.
- Respuestas de error verbosas.
- Datos de prueba.
- Versiones no definitivas de aplicaciones.
- Controles de autenticación incompletos.

Interpretación

La existencia de estos subdominios no constituye una vulnerabilidad por sí misma. Muchas organizaciones exponen entornos no productivos de forma controlada y protegida.

Sin embargo, desde una perspectiva de superficie de ataque, estos activos deben priorizarse para revisión manual porque históricamente los entornos no productivos presentan mayor probabilidad de errores de configuración.

7.5 Entornos de desarrollo, staging, testing y UAT

```
stage.luminor.lv
stage-aws.luminor.lv
test.luminor.lv
uat-investments.luminor.lv
pp-investments.luminor.lv
```

```
api.stg.manapensija.luminor.lv  
manapensija.dev.luminor.lv  
manapensija.stg.luminor.lv  
manapensija.tst.luminor.lv  
kredits.stg.luminor.lv  
kredits.tst.luminor.lv  
stg.manapensija.luminor.lv
```

La presencia de estos activos es uno de los puntos más relevantes del reconocimiento.

Riesgos potenciales asociados

Los entornos no productivos pueden presentar riesgos como:

- Autenticación débil o ausente.
- Datos reales en entornos de prueba.
- Debug activo.
- Mensajes de error detallados.
- Versiones antiguas de frameworks.
- Paneles administrativos expuestos.
- APIs incompletamente protegidas.
- Documentación técnica accesible.
- Configuración CORS permisiva.
- Credenciales de prueba reutilizadas.

Valor analítico

Este hallazgo debe clasificarse como **riesgo potencial de superficie**, no como vulnerabilidad confirmada.

La exposición pública de entornos de staging, testing o UAT no es necesariamente insegura, pero sí merece revisión porque amplía la superficie externa de la organización.

7.6 Servicios Microsoft, identidad y enrolamiento empresarial

```
autodiscover.luminor.lv  
msoid.luminor.lv  
enterpriseenrollment.luminor.lv  
enterpriseregistration.luminor.lv
```

Estos activos parecen estar relacionados con servicios Microsoft, identidad corporativa, Microsoft 365, Azure AD, Intune, enrolamiento de dispositivos o servicios empresariales.

Interés desde Red Team

Este tipo de activos puede aportar información sobre:

- Uso de Microsoft 365.
- Infraestructura de identidad.
- Servicios de enrolamiento.
- Configuración empresarial.
- Posibles vectores de phishing o password spraying, aunque estos no forman parte del presente análisis.

Nota de seguridad

No se realizó ningún intento de autenticación, enumeración de usuarios, password spraying ni interacción agresiva con servicios de identidad.

8. Detección de WAF/CDN

La herramienta detectó presencia de WAF/CDN en múltiples activos.

8.1 Cloudflare

Se detectó Cloudflare en numerosos subdominios, entre ellos:

```
kredits.stg.luminor.lv
stage.luminor.lv
old.luminor.lv
kredits.luminor.lv
manapensija.luminor.lv
nakotneses.luminor.lv
ib.luminor.lv
api.stg.manapensija.luminor.lv
investments.luminor.lv
api.manapensija.luminor.lv
sllv-secure.luminor.lv
luminor.lv
stage-aws.luminor.lv
manapensija.stg.luminor.lv
manapensija.tst.luminor.lv
bloom.luminor.lv
pp-investments.luminor.lv
manapensija-new.luminor.lv
kredits.tst.luminor.lv
test.luminor.lv
trade.luminor.lv
stg.manapensija.luminor.lv
manapensija.dev.luminor.lv
www.luminor.lv
join.luminor.lv
uat-investments.luminor.lv
```

Interpretación

La presencia de Cloudflare indica que estos activos están protegidos por una capa intermedia que puede proporcionar:

- Proxy inverso.
- Mitigación DDoS.
- WAF.
- Caching.
- Ocultación de la IP origen.
- Reglas de seguridad perimetral.
- Rate limiting.
- Control de tráfico malicioso.

Desde el punto de vista del reconocimiento, esto tiene dos implicaciones importantes:

1. La IP observada puede no corresponder al servidor origen real.
2. Los resultados de escaneos de puertos sobre esas IPs pueden corresponder a la infraestructura de Cloudflare y no a servicios propios del objetivo.

8.2 Azure Front Door / Microsoft

También se detectó infraestructura asociada a Microsoft/Azure en:

```
enterpriseenrollment.luminor.lv
```

Además, otros activos como `msoid.luminor.lv`, `enterpriseenrollment.luminor.lv`, `enterpriseregistration.luminor.lv` y `autodiscover.luminor.lv` parecen estar vinculados funcionalmente a servicios Microsoft.

Interpretación

Azure Front Door y servicios Microsoft pueden actuar como capa de entrada, balanceo, identidad, enrolamiento o servicio cloud administrado.

Desde una perspectiva de reporte, estos activos deben analizarse con cuidado para no confundir configuraciones normales de SaaS/cloud con vulnerabilidades propias de la organización.

9. Resultados TLS

La herramienta identificó varios casos de posible `TLS mismatch`.

Host	Expirado	Self-signed	Mismatch
cdnpb.ib.luminor.lv	No	No	Sí
alb.new.luminor.lv	No	No	Sí
msoid.luminor.lv	No	No	Sí
enterpriseenrollment.luminor.lv	No	No	Sí
enterpriseregistration.luminor.lv	No	No	Sí

9.1 Interpretación técnica

Un `TLS mismatch` indica que el certificado presentado por el servidor no coincide completamente con el nombre de host solicitado.

Esto puede deberse a diferentes causas:

- Configuración incorrecta de certificados.
- Uso de CNAME hacia proveedores externos.
- Servicios SaaS o cloud administrados.
- Hosts no destinados a navegación directa.
- Configuraciones heredadas.
- Reverse proxies o balanceadores.
- Servicios Microsoft/Azure.
- Infraestructura CDN.

9.2 Severidad

La severidad de estos hallazgos debe considerarse baja o informativa hasta que se demuestre un impacto adicional.

Un certificado con mismatch puede afectar a la confianza del navegador o a la experiencia del usuario, pero no implica automáticamente explotación, compromiso o fuga de datos.

Clasificación propuesta

Host	Clasificación preliminar	Motivo
cdnpb.ib.luminor.lv	Informativo/Medio potencial	Relación aparente con banca online
alb.new.luminor.lv	Informativo/Medio potencial	Posible balanceador o entorno nuevo
msoid.luminor.lv	Informativo	Posible servicio Microsoft

Host	Clasificación preliminar	Motivo
<code>enterpriseenrollment.luminor.lv</code>	Informativo	Posible enrolamiento Microsoft/Azure
<code>enterpriseregistration.luminor.lv</code>	Informativo	Posible registro empresarial Microsoft/Azure

9.3 Activos TLS que merecerían revisión posterior

Los activos más interesantes para una validación manual serían:

```
alb.new.luminor.lv
cdnpb.ib.luminor.lv
```

Motivo:

- `alb.new.luminor.lv` puede sugerir un Application Load Balancer o un entorno nuevo.
- `cdnpb.ib.luminor.lv` parece relacionado con `ib`, posiblemente banca online.

En cualquier caso, la validación debería limitarse a comprobaciones no intrusivas, como revisar el certificado presentado, su issuer, SANs, fechas de validez y cadena de confianza.

10. Puertos y servicios detectados

La herramienta reportó un total de 318 puertos abiertos en la fase preliminar de escaneo.

Sin embargo, el análisis manual del resultado indica que muchos de estos puertos aparecen asociados a IPs vinculadas a infraestructura CDN/WAF, especialmente Cloudflare.

Ejemplos de IPs observadas:

```
141.101.90.104
141.101.90.106
104.18.25.84
```

En múltiples subdominios se detectaron puertos como:

```
714
993
999
2022
3814
5225
```

```
6002
7007
7070
11111
1058
1082
1093
1110
9998
8080
```

10.1 Ejemplo de resultados observados

Algunos ejemplos del informe generado:

```
kredits.stg.luminor.lv | 141.101.90.104 | 714 | tcp | iris-xpcs
kredits.stg.luminor.lv | 141.101.90.104 | 993 | tcp | imaps
kredits.stg.luminor.lv | 141.101.90.104 | 2022 | tcp | down
kredits.stg.luminor.lv | 141.101.90.104 | 6002 | tcp | X11:2
kredits.stg.luminor.lv | 141.101.90.104 | 7070 | tcp | realserver
kredits.stg.luminor.lv | 141.101.90.104 | 11111 | tcp | vce
```

Estos mismos patrones aparecen repetidos en varios subdominios que también fueron identificados como protegidos por Cloudflare.

10.2 Interpretación crítica

Estos resultados no deben interpretarse automáticamente como servicios propios expuestos por la organización.

Cuando un dominio resuelve a Cloudflare, Akamai, Fastly, Azure Front Door u otra capa CDN/WAF, el escaneo puede estar midiendo la superficie del proveedor intermedio y no la infraestructura origen real.

Por tanto, el hallazgo debe clasificarse como:

Campo	Evaluación
Tipo	Resultado preliminar de escaneo
Severidad	Informativa
Confianza	Baja/Media
Estado	Requiere validación
Riesgo confirmado	No confirmado

10.3 Valor metodológico

Este punto es importante desde una perspectiva profesional porque demuestra que un informe de reconocimiento no debe limitarse a listar resultados automáticos.

Es necesario interpretar los datos y diferenciar entre:

- Infraestructura propia del objetivo.
- Infraestructura de terceros.
- CDN/WAF.
- Servicios cloud administrados.
- Falsos positivos de escaneo.
- Servicios realmente expuestos.

Un informe que eleva automáticamente a riesgo alto todos los puertos detectados en IPs de Cloudflare puede generar conclusiones incorrectas.

11. Resultados de Nuclei

La fase automatizada con Nuclei no detectó vulnerabilidades.

Vulnerabilidades Nuclei: Sin findings

11.1 Interpretación

La ausencia de findings en Nuclei indica que, con las plantillas y configuración utilizadas, no se identificaron vulnerabilidades conocidas, exposiciones comunes o patrones detectables automáticamente.

Esto no significa que los activos sean seguros. Significa únicamente que no se detectaron vulnerabilidades automáticas en esta fase.

11.2 Implicaciones

A partir de este punto, una fase posterior debería centrarse en análisis manual, especialmente sobre:

- APIs.
- Ficheros JavaScript.
- Flujos de onboarding.
- Entornos dev/stg/tst/uat.
- Configuración CORS.
- Cabeceras HTTP.
- Redirects.
- Autorización.

- Gestión de sesión.
- Posibles documentos o endpoints expuestos.

12. Ficheros JavaScript y URLs

La herramienta detectó:

Recurso	Cantidad
URLs encontradas	79
Ficheros JavaScript	15

Aunque en el fragmento analizado no se incluye el detalle completo de estos recursos, su existencia es relevante para una fase posterior.

12.1 Importancia de los ficheros JavaScript

Los ficheros JavaScript en aplicaciones web modernas pueden revelar información útil durante una fase de reconocimiento, como:

- Endpoints de API.
- Rutas internas.
- Nombres de servicios.
- Client IDs.
- Claves públicas de servicios externos.
- Configuración de entornos.
- Feature flags.
- URLs de staging o desarrollo.
- Referencias a documentación.
- Parámetros esperados por la aplicación.

12.2 Posibles búsquedas posteriores

En una fase controlada, los JS podrían revisarse buscando patrones como:

```
api
auth
token
client_id
secret
bearer
graphql
swagger
openapi
s3
blob
```

firebase
sentry
amplitude
segment
redirect
callback

Esta revisión puede aportar más valor que el escaneo masivo de puertos, especialmente cuando la infraestructura está detrás de CDN/WAF.

13. Priorización de activos

La siguiente tabla resume los activos que, por nombre y función aparente, serían más interesantes para una fase posterior de análisis manual.

Prioridad	Activo	Motivo
Alta	onboarding.luminor.lv	Posible flujo de alta o incorporación
Alta	photo-onboarding.luminor.lv	Posible tratamiento de documentación o imagen
Alta	business-onboarding.luminor.lv	Onboarding empresarial
Alta	business-join.luminor.lv	Alta o incorporación de empresas
Alta	business-remote.luminor.lv	Posible acceso remoto empresarial
Alta	business-videocall.luminor.lv	Posible validación por videollamada
Alta	ib.luminor.lv	Banca online
Alta	trade.luminor.lv	Posible plataforma de trading
Alta	investments.luminor.lv	Servicios de inversión
Alta	api.manapensija.luminor.lv	API pública
Media/Alta	api.stg.manapensija.luminor.lv	API en staging
Media/Alta	manapensija.dev.luminor.lv	Entorno dev accesible
Media/Alta	manapensija.stg.luminor.lv	Entorno staging
Media/Alta	manapensija.tst.luminor.lv	Entorno test
Media/Alta	kredits.stg.luminor.lv	Entorno staging financiero
Media/Alta	kredits.tst.luminor.lv	Entorno test financiero
Media	stage.luminor.lv	Entorno staging genérico
Media	stage-aws.luminor.lv	Posible entorno cloud/staging
Media	uat-investments.luminor.lv	UAT asociado a inversiones
Media	pp-investments.luminor.lv	Posible preproducción

Prioridad	Activo	Motivo
Media	<code>alb.new.luminor.lv</code>	Posible balanceador o entorno nuevo
Media	<code>cdnpb.ib.luminor.lv</code>	Asociado a banca online y TLS mismatch
Media	<code>old.luminor.lv</code>	Posible activo heredado

14. Posibles líneas de análisis posterior

Las siguientes líneas de análisis serían las más adecuadas en una fase posterior autorizada.

14.1 APIs

Activos relevantes:

```
api.manapensija.luminor.lv
api.stg.manapensija.luminor.lv
```

Líneas de revisión:

- Enumeración de endpoints públicos.
- Métodos HTTP permitidos.
- Autenticación requerida.
- Autorización por objeto.
- IDOR.
- Rate limiting.
- CORS.
- Exposición de documentación Swagger/OpenAPI.
- Respuestas de error.
- Versionado de API.

14.2 Flujos de onboarding

Activos relevantes:

```
onboarding.luminor.lv
photo-onboarding.luminor.lv
business-onboarding.luminor.lv
business-join.luminor.lv
join.luminor.lv
```

Líneas de revisión:

- Manipulación de parámetros.
- Acceso directo a pasos intermedios.
- Tokens temporales.

- Reutilización de enlaces.
- Expiración de sesiones.
- Control de acceso.
- Subida de archivos.
- Exposición de documentos.
- Validación de identidad.

14.3 Entornos no productivos

Activos relevantes:

```
stage.luminor.lv
stage-aws.luminor.lv
test.luminor.lv
uat-investments.luminor.lv
manapensija.dev.luminor.lv
manapensija.stg.luminor.lv
manapensija.tst.luminor.lv
kredits.stg.luminor.lv
kredits.tst.luminor.lv
```

Líneas de revisión:

- Presencia de autenticación.
- Errores verbosos.
- Debug activo.
- Datos reales en entornos no productivos.
- Paneles administrativos.
- Documentación expuesta.
- Versiones antiguas.
- Cabeceras inseguras.
- Configuración CORS.

14.4 JavaScript

Líneas de revisión:

- Endpoints ocultos.
- Rutas internas.
- Client IDs.
- Tokens embebidos accidentalmente.
- Claves públicas de terceros.
- URLs de entornos internos.
- Feature flags.
- Configuración del frontend.

14.5 TLS y certificados

Activos relevantes:

```
alb.new.luminor.lv  
cdnpb.ib.luminor.lv  
msoid.luminor.lv  
enterpriseenrollment.luminor.lv  
enterpriseregistration.luminor.lv
```

Líneas de revisión:

- Subject del certificado.
- Issuer.
- SANs.
- Fechas de validez.
- Cadena de confianza.
- Relación con proveedores externos.
- Posible mala configuración.

14.6 Cabeceras y configuración HTTP

Líneas de revisión:

- Content-Security-Policy.
- Strict-Transport-Security.
- X-Frame-Options.
- X-Content-Type-Options.
- Referrer-Policy.
- Permissions-Policy.
- Cookies con Secure/HttpOnly/SameSite.
- Redirecciones HTTP a HTTPS.

15. Evaluación de riesgo

La herramienta clasificó inicialmente el resultado como:

Risk Level: HIGH

Sin embargo, tras la revisión crítica de la evidencia, la clasificación debería matizarse.

15.1 Evaluación corregida

Categoría	Evaluación
Riesgo confirmado	Bajo/Medio
Riesgo potencial	Medio/Alto

Categoría	Evaluación
Valor de reconocimiento	Alto
Vulnerabilidades confirmadas	Ninguna
Hallazgos explotables	No confirmados
Superficie externa	Amplia
Necesidad de revisión manual	Alta

15.2 Justificación

El riesgo potencial es relevante por varios motivos:

- Se identificaron 41 subdominios vivos.
- Existen activos aparentemente relacionados con banca, inversión y onboarding.
- Hay varios entornos dev/stg/tst/uat accesibles públicamente.
- Se detectaron APIs y servicios potencialmente sensibles.
- Existen certificados con mismatch.
- La superficie está protegida en gran parte por Cloudflare, pero sigue siendo amplia.

No obstante, el riesgo confirmado debe rebajarse porque:

- Nuclei no detectó vulnerabilidades.
- No se validó ninguna explotación.
- No se accedió a datos sensibles.
- Los puertos detectados parecen asociados en gran parte a CDN/WAF.
- Los TLS mismatch pueden deberse a proveedores externos.
- No se confirmó exposición directa de infraestructura origen.

16. Hallazgos principales

16.1 Superficie web amplia

Se identificaron 41 subdominios vivos vía HTTP/HTTPS.

Clasificación: Informativo / Superficie de ataque

Impacto potencial: Medio

Confianza: Alta

16.2 Presencia de entornos no productivos

Se identificaron subdominios con nomenclatura asociada a desarrollo, staging, testing y UAT.

Ejemplos:

```
manapensija.dev.luminor.lv  
manapensija.stg.luminor.lv  
manapensija.tst.luminor.lv  
kredits.stg.luminor.lv  
kredits.tst.luminor.lv  
stage.luminor.lv  
stage-aws.luminor.lv  
test.luminor.lv  
uat-investments.luminor.lv
```

Clasificación: Riesgo potencial

Impacto potencial: Medio/Alto

Confianza: Media

Estado: Requiere validación manual

16.3 Activos sensibles por función aparente

Se identificaron activos relacionados con banca, inversión, onboarding y videollamada.

Ejemplos:

```
ib.luminor.lv  
investments.luminor.lv  
trade.luminor.lv  
onboarding.luminor.lv  
photo-onboarding.luminor.lv  
business-videocall.luminor.lv
```

Clasificación: Priorización de superficie

Impacto potencial: Alto

Confianza: Media

Estado: Sin vulnerabilidad confirmada

16.4 TLS mismatch en varios hosts

Se identificaron varios hosts con certificado TLS no coincidente.

```
cdnpb.ib.luminor.lv  
alb.new.luminor.lv  
msoid.luminor.lv  
enterpriseenrollment.luminor.lv  
enterpriseregistration.luminor.lv
```

Clasificación: Informativo / Configuración

Impacto potencial: Bajo/Medio

Confianza: Media

Estado: Requiere validación manual

16.5 Puertos detectados en infraestructura CDN/WAF

La herramienta reportó 318 puertos abiertos, pero muchos parecen asociados a IPs de Cloudflare.

Clasificación: Informativo

Impacto potencial: Bajo hasta validación

Confianza: Baja/Media

Estado: Probable ruido de escaneo sobre CDN/WAF

16.6 Sin vulnerabilidades detectadas por Nuclei

No se detectaron vulnerabilidades automáticas.

Clasificación: Resultado negativo

Impacto: No aplica

Confianza: Alta respecto a la ejecución realizada

17. Interpretación desde perspectiva Red Team

Este reconocimiento demuestra una parte fundamental de cualquier operación Red Team: la capacidad de mapear la superficie externa antes de seleccionar vectores de entrada.

El valor principal de esta fase no está en haber encontrado una vulnerabilidad explotable, sino en haber construido una imagen inicial de:

- Qué activos existen.
- Cuáles están vivos.
- Qué activos parecen más sensibles.
- Qué servicios están detrás de CDN/WAF.
- Qué resultados automáticos deben validarse manualmente.
- Qué activos deberían priorizarse en una fase posterior.

Desde una perspectiva profesional, el análisis también muestra la importancia de no aceptar de forma literal todos los resultados automáticos.

Por ejemplo, el motor inicial clasificó el riesgo como alto, pero la revisión manual permite concluir que se trata de un riesgo alto en términos de superficie potencial, no de una vulnerabilidad crítica confirmada.

18. Mejoras identificadas para la herramienta Cerberus Search

Durante la revisión del informe se identificaron varias mejoras aplicables a la herramienta.

18.1 Diferenciar infraestructura propia y CDN/WAF

La herramienta debería identificar si una IP pertenece a proveedores como:

- Cloudflare.
- Akamai.
- Fastly.
- Azure Front Door.
- AWS CloudFront.
- Google Cloud CDN.

Si el host resuelve a una IP de CDN/WAF, los puertos detectados no deberían sumar directamente al riesgo del target.

Regla propuesta

```
Si IP pertenece a CDN/WAF:  
  clasificar puertos como CDN_EDGE_PORTS  
  severidad máxima: Informativa  
  no sumar al risk score del objetivo
```

18.2 Rebajar TLS mismatch en servicios SaaS

Los TLS mismatch en hosts relacionados con Microsoft, Azure o servicios SaaS no deberían marcarse como críticos sin validación adicional.

Regla propuesta

```
Si TLS mismatch aparece en host Microsoft/Azure/SaaS:  
  severidad máxima: Informativa/Baja  
  salvo que exista takeover, certificado caducado o impacto demostrado
```

18.3 Bloquear clasificación HIGH si no hay vulnerabilidad confirmada

El motor de scoring no debería asignar automáticamente **HIGH** cuando no existen findings de Nuclei ni evidencias explotables.

Regla propuesta

Si Nuclei no encuentra findings
y no hay secrets válidos
y no hay takeover verificable
y no hay datos sensibles expuestos
y no hay panel crítico accesible
entonces:
 impedir clasificación HIGH

18.4 Separar “Recon Value” de “Risk Level”

Una mejora importante sería separar dos conceptos:

Concepto	Significado
Recon Value	Valor del reconocimiento para priorizar objetivos
Risk Level	Riesgo técnico confirmado o potencial

En este caso, el análisis tendría:

Recon Value: High
Confirmed Risk: Low/Medium
Potential Surface Risk: Medium/High

Esta separación haría el informe más preciso y evitaría sobredimensionar hallazgos.

18.5 Añadir explicación automática de falsos positivos

La herramienta debería añadir notas automáticas cuando detecte patrones de posible falso positivo.

Ejemplo:

Se han detectado múltiples puertos abiertos en IPs asociadas a Cloudflare. Estos puertos pueden corresponder a infraestructura del proveedor CDN/WAF y no necesariamente a servicios propios del objetivo. Se recomienda validación manual antes de considerarlos exposición real.

19. Recomendaciones defensivas generales

Para una organización con una superficie similar, las recomendaciones defensivas generales serían:

- Mantener un inventario actualizado de subdominios.
- Revisar periódicamente activos expuestos en Internet.

- Validar si los entornos dev/stg/tst/uat deben ser públicos.
- Proteger entornos no productivos mediante autenticación fuerte.
- Evitar datos reales en entornos de prueba.
- Revisar configuraciones TLS con mismatch.
- Comprobar delegaciones CNAME hacia terceros.
- Monitorizar exposición de APIs.
- Revisar ficheros JavaScript en busca de endpoints o secretos.
- Validar políticas CORS.
- Aplicar cabeceras HTTP de seguridad.
- Diferenciar en monitorización entre infraestructura propia y CDN/WAF.
- Ejecutar escaneos periódicos de superficie externa.

20. Conclusiones

El reconocimiento externo sobre `luminor.lv` permitió identificar una superficie pública amplia y funcionalmente diversa, con activos asociados a banca, inversión, onboarding, videollamada, APIs, servicios Microsoft/Azure y entornos no productivos.

La herramienta Cerberus Search fue útil para automatizar la fase inicial de enumeración y generar un inventario de activos, pero el informe generado requirió una revisión crítica posterior para evitar una interpretación excesiva del riesgo.

Los puntos más relevantes del análisis fueron:

- Se identificaron 78 subdominios en fase pasiva.
- 51 subdominios resolvían por DNS.
- 41 subdominios respondían vía HTTP/HTTPS.
- Se detectaron activos relacionados con banca, inversión y onboarding.
- Se identificaron entornos dev, stg, tst, stage y uat.
- Se detectó uso extendido de Cloudflare como WAF/CDN.
- Se observaron activos asociados a Microsoft/Azure.
- Se identificaron TLS mismatch en varios hosts.
- Se reportaron 318 puertos en el escaneo preliminar, aunque muchos parecen asociados a CDN/WAF.
- Nuclei no detectó vulnerabilidades.

La conclusión principal es que no se confirmó ninguna vulnerabilidad explotable, pero sí se obtuvo un mapa útil de superficie externa.

Desde una perspectiva Red Team, este anexo demuestra la importancia de combinar automatización con análisis manual. Las herramientas pueden acelerar la enumeración, pero la interpretación técnica sigue siendo esencial para diferenciar entre riesgo real, riesgo potencial, ruido de escaneo y falsos positivos.

21. Estado final del análisis

Campo	Resultado
Tipo de resultado	Reconocimiento externo
Vulnerabilidad confirmada	No
Hallazgos explotables	No confirmados
Valor del análisis	Alto para mapeo de superficie
Riesgo potencial	Medio/Alto
Riesgo confirmado	Bajo/Medio
Siguiente fase recomendada	Validación manual controlada
Uso recomendado en el ejercicio	Anexo técnico

Documento generado como parte del ejercicio de formación en Red Team – Abril 2026